

Module 13 Assignment:
OWASP Threat Modeling:
Secure SDLC and OWASP Top 10
JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

Introduction

The OWASP Top 10:2025 provides a practical framework for identifying the most critical risks affecting modern web applications, particularly those handling user-generated content. This paper analyzes five OWASP vulnerabilities most relevant to a multi-tenant document-sharing platform, outlines mitigation strategies, and explains how each integrates into the Secure SDLC. In a multi-tenant environment, strict isolation, confidentiality, and predictable access behavior are baseline expectations. Secure SDLC begins before development and must remain embedded through threat modeling, secure design, and continuous testing across the lifecycle.

A01:2025 – Broken Access Control

Broken Access Control remains the top OWASP risk, with 40 CWEs and nearly 34K CVEs. The Adobe 2013 breach demonstrated how weak internal authorization allowed attackers to move laterally into systems storing customer-uploaded files. Overly broad internal permissions and the absence of tenant-level boundaries meant that once attackers reached the storage layer, nothing prevented cross-customer access.

A multi-tenant document-sharing platform faces the same risk: inconsistent or by-passable authorization enables users or attackers to manipulate identifiers and retrieve documents outside their tenant. Secure SDLC mitigates this through Zero Trust, least privilege, and strict control over what is exposed at every layer. Every request—internal or external—must be validated for identity, tenant, and authorization. Sensitive identifiers must not appear in URLs, storage paths must not be directly reachable, and open ports or directories must be minimized. These controls are defined early, implemented consistently, validated through automated testing, and monitored continuously to prevent escalation even if one component is compromised.

A02:2025 Security Misconfiguration

Security misconfiguration was also a contributing factor in the Adobe 2013 breach, and it remains one of the most common root causes of data exposure in modern cloud applications. In Adobe's case, attackers were able to access internal systems and repositories because several services were deployed with overly permissive configurations, insufficient segmentation, and inconsistent hardening. This allowed broad access to systems that stored customer-uploaded files, and default or legacy settings created pathways for lateral movement.

In a secure SDLC, these risks are mitigated through Zero Trust architecture, least-privilege access, and rigorous configuration hardening across every environment, and minimizing what is exposed through the application surface: avoiding sensitive identifiers in URLs, restricting open ports, disabling unused services, removing default accounts and passwords, and ensuring no directory or storage location is directly reachable without authorization checks. These controls are defined early, enforced through Infrastructure-as-Code, validated in CI/CD, and continuously monitored in production to prevent the types of gaps seen in Adobe's environment.

A04:2025 Cryptographic Failures

Cryptographic failure was a central factor in the Adobe 2013 breach, and the lesson applies directly to any multi-tenant file-sharing platform. Adobe stored passwords using reversible encryption and reused the same key across millions of records. Once attackers accessed the encrypted database, the lack of proper key management meant the entire credential set -- and therefore access to user accounts and uploaded files -- was effectively compromised. The issue wasn't just weak crypto; it was the absence of tenant-level separation and the use of a single point of failure for sensitive data.

In a multi-tenant platform, weak encryption or shared keys can expose all tenants in a single breach. Secure SDLC requires strong encryption in transit and at rest, tenant-scoped or

per-resource keys, regular rotation, and ensuring no sensitive identifiers or tokens leak through URLs or logs. Cryptography ultimately determines whether a compromise is contained or cascades across the platform.

A05:2025 Injection

Injection remains a high-impact risk in a multi-tenant document-sharing platform because user-controlled input flows into search queries, metadata fields, tagging systems, and tenant-scoped database filters. With 1.4 million recorded occurrences in the OWASP dataset, the pattern is clear: many applications still accept raw input directly into internal logic instead of enforcing strict API boundaries and parameterization. UTM parameters are a common example—marketing teams often use them to pass identifiers or trigger behaviors, effectively allowing unvalidated URL parameters to influence application logic.

In a multi-tenant model, a single injection flaw or misuse of UTM parameters can escalate into cross-tenant data exposure, document enumeration, or manipulation of access rules. Secure SDLC mitigates this by enforcing API-first architecture, centralized validation, and strict separation of user input from backend logic, with automated SAST/DAST and integration tests ensuring these controls remain intact throughout development and deployment.

A09:2025 Security Logging & Alerting Failures

Security logging and alerting failures remain one of the most difficult internal challenges despite having only five CWEs mapped in the OWASP dataset. Effective detection requires consistent frameworks for generating, storing, and reviewing audit data, yet many organizations still rely on local logs that lack centralization, back up, or clear ownership. OWASP’s observation that “detected alerts cannot be processed correctly because the playbook for the use case is incomplete, out of date, or missing” reflects a common failure mode seen in the Adobe

2013 breach, where gaps in monitoring and response allowed attackers to move laterally without timely detection.

The same risk applies to a multi-tenant document-sharing platform: without tenant-aware audit trails, centralized log aggregation, and clear operational playbooks, cross-tenant anomalies or unauthorized document access can go unnoticed. Secure SDLC mitigates this by integrating logging requirements from the threat-modeling phase forward, defining and maintaining actionable playbooks, and aligning detection use cases with both existing and emerging CVEs. Continuous validation in CI/CD and regular review of alerting workflows ensure that logging remains a living control rather than an afterthought.

Conclusion

The Adobe 2013 breach illustrates how multiple OWASP Top 10 failures can converge—weak access controls, misconfigurations, cryptographic flaws, insufficient input handling, and ineffective logging all contributed to the scale of the compromise. While this analysis focuses on a multi-tenant application model, Adobe is only one example; most major breaches over the past decade map to several of these same OWASP categories. The overlap is consistent because these vulnerabilities represent structural weaknesses in how modern applications are designed, deployed, and monitored. For a multi-tenant document-sharing platform, the implications are direct: a single lapse in any of these areas can propagate across tenants and undermine the entire trust model. Integrating OWASP controls throughout the Secure SDLC—from threat modeling through deployment and operational monitoring—ensures these vulnerabilities are addressed systematically rather than reactively, preserving tenant isolation and predictable system behavior at scale.

References

- BeamSec. (2024). OWASP Top 10 2025: What changed and why it matters. <https://beamsec.com/owasp-top-10-2025-what-changed-and-why-it-matters/>
- OWASP Foundation. (2021). *OWASP Top Ten Web Application Security Risks*. <https://owasp.org/www-project-top-ten/>
- OWASP Foundation. (2025). A01:2025 – Broken access control. https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/
- OWASP Foundation. (2025). A02:2025 – Security misconfiguration. https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
- OWASP Foundation. (2025). A04:2025 – Cryptographic failures. https://owasp.org/Top10/2025/A04_2025-Cryptographic_Failures/
- OWASP Foundation. (2025). A05:2025 – Injection. https://owasp.org/Top10/2025/A05_2025-Injection/
- OWASP Foundation. (2025). A09:2025 – Security logging and alerting failures. https://owasp.org/Top10/2025/A09_2025-Security_Logging_and_Alerting_Failures/
- OWASP Foundation. (n.d.). OWASP in SDLC. https://owasp.org/www-project-integration-standards/writeups/owasp_in_sdlc/
- Sawant, A. (2026). Secure SDLC and OWASP Top 10 [Online course]. Coursera & Northeastern University.

Methodology and Use of AI Tools

I used Microsoft Copilot as a writing and organizational aid to help structure the report, tighten up my draft, refine transitions between sections, and ensure alignment with the assignment rubric. All analysis, interpretations, and conclusions reflect my own understanding of the material and the concepts covered in Module 13.